

CHOFYAI STUDIO

11 · Seguridad

Documento	11-security.md
Versión analizada	0.5.1 (commit f840055)
Fecha del análisis	2026-08-28
Fuente Markdown	docs/system-documentation/11-security.md
Generado por	scripts/docs/build-pdf.mjs

Contenido

ChofyAI Studio · 11 · Seguridad

v0.5.1 (commit f840055) · 2026-08-28

1. Modelo de amenaza
 - Superficie de entrada
2. Autenticación, autorización, roles y sesiones
3. Ejecución de comandos y procesos
 - 3.1 Interpolación del ``run.command``
 - 3.2 Escapado en ``notify_macos``
 - 3.3 El pre-flight que mata procesos ajenos
4. Validación y saneamiento de entradas
 - Controles presentes
 - Controles ausentes
5. Gestión de secretos
6. Cifrado y protección de datos
7. Datos personales
8. Exposición de red
9. CORS, CSRF y carga de archivos
10. Cadena de suministro
 - Controles del proyecto
 - El punto débil
11. Controles implementados y ausentes
 - Implementados
 - Ausentes o no comprobados
12. Resumen priorizado de riesgos

Estado: completo · Última revisión: 2026-08-27 · Versión analizada: 0.5.1 (commit f840055)

Análisis de seguridad realizado **por lectura estática del repositorio**. No se ejecutaron ataques, escaneos activos ni pruebas destructivas. Cada hallazgo indica el archivo y el símbolo donde se comprueba. Los hallazgos se recogen priorizados en la sección 12 y se cruzan con [15 · Riesgos y deuda técnica](#).

1. Modelo de amenaza

ChofyAI Studio es una aplicación de escritorio **monousuario** que se ejecuta con los privilegios de la sesión del usuario y cuyo trabajo consiste, literalmente, en **descargar código de terceros de internet y ejecutarlo**. Ese es el marco en el que hay que leer todo lo que sigue: la aplicación no puede ser más segura que el código que instala.

Supuestos de partida:

- El atacante **no** tiene acceso al equipo del usuario. Si lo tiene, ya puede hacer todo lo que hace la aplicación sin necesidad de ella.
- El repositorio y sus manifiestos son confiables mientras no se modifiquen.
- Los repositorios de terceros que se clonan **no** están bajo control del proyecto.

Superficie de entrada

Entrada	Confiabilidad	Puerta
apps/*.yaml	Versionados, pero editables en disco y generables por import_marketplace_tool	collect_manifests
marketplace/registry.yaml	Versionado	list_marketplace_tools
workflows/*.yaml	Versionados y escribibles desde la interfaz	list_workflows , save_workflow
storage/state/settings.json	Editable en disco	load_settings
Salida de los scripts y de las herramientas	No confiable	Logs, cola de instalación, LogsViewer
Respuestas HTTP de las herramientas locales	No confiable	runWorkflowStep
Contenido embebido en el iframe	No confiable	Vista Ver UI
Código y modelos descargados	No confiable	Scripts de instalación
Dependencias npm, cargo y pip	Parcialmente controladas	Lockfiles y auditorías

2. Autenticación, autorización, roles y sesiones

No existen. Verificado por ausencia: no hay pantallas de acceso, ni tokens, ni comprobaciones de rol en `src-tauri/src/system.rs` , ni middleware de ningún tipo. Cualquier comando puede invocarse desde el WebView sin restricción.

Implicaciones honestas:

- Cualquier proceso que corra como el usuario puede editar `settings.json` o un manifiesto y cambiar lo que la aplicación ejecutará después.
- No hay separación entre "operar" y "configurar": quien abre la ventana puede reubicar módulos, borrar modelos y matar procesos.

El único control real es el del sistema operativo. Dentro de la aplicación, el modelo de permisos es el de Tauri:

Elemento	Valor	Lectura de seguridad
<code>capabilities/default.json</code>	Sólo <code>core:default</code> para la ventana <code>main</code>	Correcto: no se habilitan plugins de disco o shell accesibles desde JavaScript
<code>tauri.conf.json</code> → <code>app.security.csp</code>	<code>null</code>	Sin política de contenido: el WebView puede cargar y ejecutar cualquier origen

La CSP nula es funcionalmente necesaria para embeber en un `iframe` las interfaces de ComfyUI, FaceFusion o AceForge, pero significa que una herramienta local comprometida podría servir contenido que se ejecute en el mismo WebView que la aplicación. El aislamiento efectivo lo da el `iframe` , no una política declarada.

3. Ejecución de comandos y procesos

Todo lo que la aplicación ejecuta contra el sistema está en `src-tauri/src/system.rs` :

Punto	Comando ejecutado	Origen de los argumentos
ChofyAI Studio · 11 · Seguridad <code>run_install_script</code>	<code>bash <script> / pwsh <script></code>	v0.5.1 (commit f840055) · 2026-08-28 Ruta del script tomada del manifiesto
<code>start_tool</code> , <code>restart_tool</code>	<code>bash -lc "<run.command>" / pwsh -NoProfile -Command "<run.command>"</code>	Cadena del manifiesto interpolada en una shell
<code>download_tool_model</code>	<code>bash download-hf-model.sh <repo_id> <destino></code>	<code>repo_id</code> validado contra el manifiesto; argumentos pasados por <code>arg()</code> , no por shell
<code>run_doctor</code>	<code>bash doctor.sh <studio_home></code>	Ruta desde la interfaz, pasada como argumento
<code>notify_macos</code>	<code>osascript -e "display notification ..."</code>	Título y cuerpo generados por la aplicación
<code>open_in_system</code>	<code>open <ruta></code>	Ruta calculada internamente
<code>list_orphan_ports</code>	<code>lsof -nP -iTCP:<port> -sTCP:LISTEN -Fpc</code>	Puerto del manifiesto (<code>u16</code> , sin riesgo de inyección)
<code>start_tool</code> (pre-flight)	<code>lsof -ti :<port> y kill -9 <pid></code>	PID leído de <code>lsof</code>
<code>stop_tool</code> , <code>kill_orphan</code> , <code>pid_is_alive</code>	<code>kill -TERM / kill -9 / kill -0</code>	PID numérico
<code>resolve_effective_home</code>	<code>hdiutil attach -nobrowse -noverify <ruta></code>	Ruta de <code>settings.json</code> , pasada como argumento

3.1 Interpolación del `run.command`

Es el punto más delicado del backend. El contenido de `run.command` (o `run.commands[plataforma]`) se pasa **entero** a `bash -lc`, es decir, se interpreta como shell. Quien controle un manifiesto controla la ejecución de comandos arbitrarios.

Matización necesaria para no exagerar el riesgo: los manifiestos viven en el repositorio o dentro del `.app` firmado, y modificarlos ya requiere acceso de escritura al equipo o al repositorio. **No** es una inyección remota. Sí es un riesgo si en el futuro se aceptan manifiestos de fuentes externas, que es exactamente la dirección en la que apunta el marketplace.

Nota adicional: `bash -lc` carga el perfil de la shell del usuario, con lo que la ejecución hereda cualquier cosa definida en `.zprofile` o equivalente.

3.2 Escapado en `notify_macos`

```
let safe = |s: &str| s.replace("'", "\\'").replace('\n', " ");
```

Escapa comillas dobles y saltos de línea antes de construir el AppleScript. Cubre los casos que produce la propia aplicación (nombres de herramienta y mensajes de instalación). No escapa la barra invertida en sí, de modo que una entrada terminada en `\` podría alterar el escapado. Con las fuentes actuales —textos

3.3 El pre-flight que mata procesos ajenos

`start_tool` ejecuta `lsof -ti :<port> -sTCP:LISTEN` y envía `kill -9` a **todo PID que no esté en su registro**. Resuelve un problema real (procesos zombis tras un cierre forzado) pero es un riesgo de disponibilidad para el usuario: si otra aplicación suya ocupa el 7860, el 8188 o cualquier otro puerto declarado, muere sin preguntar y sin oportunidad de guardar. No hay confirmación ni registro de esa acción en un log persistente.

4. Validación y saneamiento de entradas

Controles presentes

Control	Dónde	Qué impide
Guardia de recorrido de rutas	<code>delete_tool_model</code> : rechaza <code>..</code> , hace <code>canonicalize</code> y comprueba <code>starts_with</code> sobre el directorio de modelos	Borrar archivos fuera del directorio de modelos
Sólo archivos	<code>delete_tool_model</code>	Borrado recursivo de directorios
Modelo declarado	<code>download_tool_model</code>	Descargar un repositorio arbitrario de Hugging Face
Identificador de workflow	<code>validate_workflow_id</code> : sin vacío, sin <code>/</code> , <code>\</code> , <code>..</code> , sólo <code>[a-zA-Z0-9_-]</code>	Escribir fuera de <code>workflows/</code>
Estructura del workflow	<code>save_workflow</code> : YAML válido, raíz de tipo mapa y campos obligatorios	Archivos basura en <code>workflows/</code>
Ruta absoluta y destino vacío	<code>relocate_module</code>	Sobrescribir una instalación existente
No sobrescribir	<code>import_marketplace_tool</code>	Pisar un manifiesto existente
Plataforma soportada	<code>platform_supported</code>	Ejecutar un script inexistente para el sistema actual
Integridad de instalación	<code>installed_if</code> en instalación y arranque	Arrancar una instalación corrupta

Controles ausentes

ChofyAI Studio · 11 · Seguridad

v0.5.1 (commit f840055) · 2026-08-28

Falta	Dónde	Consecuencia
Validación de <code>studio_home</code>	<code>save_studio_home</code> acepta cualquier cadena	El error aparece tarde, al instalar
Validación de <code>models_dir</code> / <code>outputs_dir</code> / <code>cache_dir</code>	<code>save_path_settings</code>	Igual que la anterior
Saneamiento del <code>id</code> del marketplace	<code>import_marketplace_tool</code> construye <code>apps/<id>.yaml</code> con el <code>id</code> tal cual	Un <code>id</code> con <code>/</code> o <code>..</code> en <code>registry.yaml</code> escribiría fuera de <code>apps/</code> . Hoy el catálogo es del propio repositorio, así que el riesgo es potencial, no explotable; pasaría a ser real con un catálogo remoto
Validación semántica del YAML de workflow	<code>save_workflow</code> sólo comprueba cuatro claves	Un workflow puede apuntar a cualquier URL, incluso externa
Esquema de <code>WorkflowDef</code> en el backend	<code>list_workflows</code> devuelve JSON sin validar	Un YAML malformado llega al render
Escapado de la salida de las herramientas	Logs y cola de instalación	Se muestra como texto en <code><pre></code> , no como HTML: React escapa por defecto, así que no hay XSS por esta vía

5. Gestión de secretos

Búsqueda realizada sobre el repositorio (excluyendo `node_modules`, `pnpm-lock.yaml` y `src-tauri/gen/`), con patrones `api_key`, `apikey`, `secret`, `token`, `password`, `passwd`, `AKIA[0-9A-Z]{16}` y `BEGIN ... PRIVATE KEY` en archivos `.ts`, `.tsx`, `.rs`, `.sh`, `.ps1`, `.json`, `.yaml`, `.yml` y `.mjs`.

Resultado: **no se encontró ninguna credencial**. Las únicas coincidencias son referencias legítimas en los workflows de CI:

- `.github/workflows/release.yml` usa `${{ secrets.GITHUB_TOKEN }}`, el token efímero que provee GitHub Actions.
- `.github/workflows/security.yml` declara el trabajo `secrets` (escaneo con TruffleHog) y el disparador `workflow_call`.
- El resto son comentarios que mencionan la palabra.

Los secretos de firma y notarización de Apple no están en el repositorio: se documentan por nombre en `../NOTARIZATION.md` y deben configurarse como secretos del repositorio en GitHub. Este documento no reproduce ningún valor.

Recordatorio operativo: `settings.json`, los manifiestos y los workflows **se versionan y además viajan dentro del `.app`** por el bloque `bundle.resources`. Nunca deben contener credenciales.

6. Cifrado y protección de datos

Aspecto	Estado
Datos en reposo	Sin cifrado propio. Depende de FileVault o del cifrado del sparsebundle APFS si el usuario lo activó
Tráfico externo	HTTPS en todos los casos: <code>git</code> sobre HTTPS, Hugging Face, PyPI, API de GitHub, jsDelivr
Tráfico local	HTTP plano contra <code>127.0.0.1</code>
Verificación de integridad de modelos	No hay comprobación de suma ni de firma tras la descarga

El HTTP plano en `127.0.0.1` es aceptable: el tráfico no sale de la interfaz de loopback. La matización relevante es que **cualquier proceso local del mismo usuario puede hablar con esos puertos**, porque no hay autenticación en las herramientas.

7. Datos personales

Dato	Dónde aparece	Sale del equipo
Nombre de usuario y rutas del home	<code>settings.json</code> , logs, mensajes de error, <code>crash.log</code>	No
Nombres de volúmenes externos	Resultado de <code>list_volume_candidates</code> , barra de estado	No
Contenido creado por el usuario	<code>outputs/</code> , peticiones a <code>127.0.0.1</code>	No
Trazas de error de la interfaz	<code>crash.log</code> , hasta 4000 caracteres de stack por entrada	No

El `settings.json` versionado en el repositorio contiene rutas reales del equipo del autor (`/Volumes/...`). No es una credencial, pero sí información del entorno que se publica con el repositorio. Recomendación: versionar un archivo de ejemplo y mantener el real fuera de control de versiones, como ya se hace con `settings.local.json` en `.gitignore` .

No se ha encontrado telemetría, analítica ni envío de datos del usuario a ningún servicio.

8. Exposición de red

Bind declarado por cada herramienta en su manifiesto:

Herramienta	Cómo se fija	Verificable en el repositorio
ChofyAI Studio · 11 · Seguridad whisper.cpp	<code>--host 127.0.0.1</code>	Sí v0.5.1 (commit f840055) · 2026-08-28
ComfyUI	<code>--listen 127.0.0.1</code>	Sí
Qwen3-TTS	<code>uvicorn --host 127.0.0.1</code>	Sí
FaceFusion	<code>GRADIO_SERVER_NAME=127.0.0.1</code>	Sí en macOS y Linux; en el comando de Windows la variable se fija con sintaxis PowerShell antes de invocar
AceForge	El script sólo sustituye el puerto 5056 por 7857 en <code>music_forge_ui.py</code> ; el bind lo decide el código de la herramienta	Requiere validación: no se puede afirmar desde este repositorio que escuche sólo en loopback

La aplicación en sí no abre ningún puerto propio.

9. CORS, CSRF y carga de archivos

- **CORS:** las peticiones de `runWorkflowStep` salen del WebView hacia `127.0.0.1` . Que funcionen depende de que la herramienta destino permita el origen; whisper.cpp y ComfyUI lo hacen en su configuración por defecto. No hay ninguna política CORS del lado de la aplicación porque no hay servidor propio.
- **CSRF:** no aplica en el sentido clásico —no hay sesiones ni cookies— , pero sí existe un riesgo análogo: cualquier página abierta en el navegador del usuario puede enviar peticiones a las herramientas locales, que no autentican a nadie. Es una propiedad de esas herramientas, no de ChofyAI Studio.
- **Carga de archivos:** `WorkflowRunner` adjunta archivos del usuario como `multipart` hacia `127.0.0.1` . No hay límite de tamaño ni validación de tipo más allá del atributo `accept` del formulario, que es una sugerencia del navegador y no un control.

10. Cadena de suministro

Controles del proyecto

Control	Evidencia
Gestor de paquetes fijado	<code>packageManager: "pnpm@10.29.3"</code> en <code>package.json</code> , instalado vía Corepack
Scripts de instalación restringidos	<code>pnpm.onlyBuiltDependencies: ["esbuild"]</code> : bloquea <code>postinstall</code> de dependencias transitivas
Lockfile obligatorio	<code>pnpm install --frozen-lockfile</code> en CI
Escaneo de secretos	TruffleHog con <code>--only-verified</code> en <code>security.yml</code>
Auditoría de dependencias	<code>pnpm audit --prod</code> y <code>cargo audit</code>
Análisis estático	CodeQL
Acciones fijadas	Comprobación de <i>pin</i> de acciones en <code>security.yml</code>
Actualización automatizada	Dependabot para npm, cargo y github-actions

El punto débil

Todo ese cuidado con las dependencias del proyecto contrasta con lo que hacen los scripts de instalación:

1. Clonan la rama por defecto de repositorios de terceros **sin fijar commit ni etiqueta** (siete repositorios distintos, listados en [09 · APIs e integraciones](#)).
2. Ejecutan el instalador propio de esas herramientas, incluido `python install.py --onnxruntime default --skip-conda` en FaceFusion.
3. Instalan paquetes de PyPI sin fijar versiones en la mayoría de los casos.
4. `update_tool` ejecuta `git pull --ff-only` y vuelve a instalar, trayendo lo que haya en ese momento.
5. No se verifica la integridad de los modelos descargados.

Es decir: **el vector de compromiso más probable no es la aplicación, sino cualquiera de los proyectos de terceros que instala**. Es inherente a lo que hace el producto, pero merece estar declarado.

11. Controles implementados y ausentes

Implementados

Control	Evidencia
Superficie IPC explícita y acotada	<code>invoke_handler</code> en <code>src-tauri/src/lib.rs</code>
Permisos mínimos de Tauri	<code>capabilities/default.json</code> con sólo <code>core:default</code>
Guardia de recorrido de rutas	<code>delete_tool_model</code>
Lista blanca de modelos descargables	<code>download_tool_model</code>
Validación de identificadores	<code>validate_workflow_id</code>
Validación de integridad de instalación	<code>installed_if</code> en dos momentos distintos
Aislamiento de las UIs de terceros	<code>iframe</code>
Escapado automático de HTML	React en todos los textos mostrados
Todo el tráfico de inferencia en loopback	<code>run.command</code> de los manifiestos
Cadena de suministro del propio proyecto	pnpm fijado, lockfile, auditorías, CodeQL, Dependabot
Registro de fallos de interfaz	<code>AppErrorBoundary</code> + <code>append_crash_log</code>

Ausentes o no comprobados

Ausencia	Recomendación
Política de contenido (<code>csp: null</code>)	Definir una CSP que permita <code>frame-src http://127.0.0.1:*</code> y restrinja el resto
Saneamiento del <code>id</code> en <code>import_marketplace_tool</code>	Aplicar la misma validación que <code>validate_workflow_id</code>
Firma o suma de verificación de modelos	Registrar el hash esperado en el manifiesto
Commit fijado en los clones	Añadir <code>commit:</code> o <code>tag:</code> al manifiesto y usarlo en el clone
Confirmación antes del <code>kill -9</code> del pre-flight	Preguntar cuando el proceso no es de una herramienta conocida
Escritura atómica de <code>settings.json</code>	Escribir a un temporal y renombrar
Validación de rutas al guardar configuración	Comprobar que sean absolutas y escribibles
Aviso ante <code>settings.json</code> corrupto	Hoy se pierde la configuración en silencio
Firma y notarización de la aplicación	Documentado en <code>./NOTARIZATION.md</code> , pendiente de ejecutar
Registro de auditoría de acciones destructivas	Añadir a <code>crash.log</code> o a un log propio los <code>kill</code> y los borrados

12. Resumen priorizado de riesgos

ID	Hallazgo	Severidad	Probabilidad	Impacto	Evidencia	Recomendación
S-01	Se clona y ejecuta código de terceros sin fijar commit ni verificar integridad	Alta	Alta	Ejecución de código arbitrario con los permisos del usuario	<code>scripts/mac/install-*.sh</code>	Fijar commits en los manifiestos y verificar sumas
S-02	<code>kill -9</code> a procesos ajenos que ocupen un puerto declarado	Media	Media	Pérdida de datos de otra aplicación del usuario	<code>start_tool</code> , bloque de pre-flight	Confirmar con el usuario o limitar a procesos conocidos
S-03	<code>csp: null</code> con <code>iframe</code> de contenido de terceros	Media	Baja	Contenido no confiable ejecutándose en el WebView	<code>src-tauri/tauri.conf.json</code>	Definir una CSP explícita
S-04	<code>run.command</code> interpolado en <code>bash -lc</code>	Media	Baja	Ejecución arbitraria si se aceptan manifiestos externos	<code>start_tool</code> , <code>shell_inline_command</code>	Validar los manifiestos importados; considerar <code>Command</code> con argumentos
S-05	<code>id</code> del marketplace sin sanear al construir la ruta del manifiesto	Media	Baja	Escritura fuera de <code>apps/</code> con un catálogo remoto	<code>import_marketplace_tool</code>	Reutilizar <code>validate_workflow_id</code>
S-06	<code>settings.json</code> corrupto se sustituye en silencio por los valores por defecto	Baja	Media	Pérdida de configuración sin aviso	<code>load_settings</code>	Distinguir "no existe" de "no parsea" y avisar
S-07	Escritura no atómica de <code>settings.json</code> y <code>processes.json</code>	Baja	Media	Archivo truncado ante un corte	<code>save_settings_to_disk</code> , <code>persist_registry</code>	Escribir a temporal y renombrar
S-08	Modelos descargados sin verificación de integridad	Baja	Baja	Modelo alterado en tránsito o en el origen	<code>download_tool_model</code>	Registrar y comprobar el hash

ID	Hallazgo	Severidad	Probabilidad	Impacto	Evidencia	Recomendación
ChofyAI Studio · 11 · Seguridad · v0.5.1 (commit f840055) · 2026-08-28						
S-09	Rutas del entorno del autor en el <code>settings.json</code> versionado	Baja	Alta	Divulgación de información del entorno	<code>storage/setting/settings.json</code>	Versionar un archivo de ejemplo
S-10	Escapado incompleto de barra invertida en <code>notify_macos</code>	Baja	Baja	Alteración del AppleScript con entradas manipuladas	<code>notify_macos</code>	Escapar también <code>\</code>
S-11	Bind de AceForge no verificable desde este repositorio	Informativo	—	Posible exposición fuera de loopback	<code>apps/aceforge.yaml</code> , <code>install-aceforge.sh</code>	Comprobar en ejecución y documentarlo
S-12	Entitlements que relajan protecciones (JIT, memoria no firmada, validación de librerías)	Informativo	—	Menor protección del proceso	<code>src-tauri/Entitlements.plist</code>	Mantener sólo los estrictamente necesarios y documentarlo

Ninguno de estos hallazgos se ha corregido: este documento es informativo, como exige el alcance del trabajo. Las correcciones deben priorizarse junto con el resto de la deuda en [15 · Riesgos y deuda técnica](#).

La política de reporte de vulnerabilidades del proyecto está en `../SECURITY.md`, y el detalle del workflow de seguridad en `../SECURITY_WORKFLOW.md`.